



INTERNAL NETWORK & WEB APPLICATION
PENETRATION TEST REPORT

INTERNAL NETWORK & WEB APPLICATION PENETRATION TEST REPORT

Cybersecurity Penetration Testing Lab: Internal Network & Web Application Security Assessment

Assessment Type: Internal Network and Web Application Penetration Test

Environment: Cybersecurity Home lab (Isolated Network)

Methodology: NIST SP 800-115 | OWASP Top 10 | MITRE ATT&CK | CVSS v3.1

Assessment Period: June 2026

Prepared By: Robes Fokoueng

Cybersecurity Professional | SOC Analyst | Offensive Security Enthusiast

Report Classification:

Classification:

Version: 1.0

Document Date: June 2026

DISCLAIMER:

This penetration test was conducted in a controlled and isolated laboratory environment for educational and professional development purposes. All testing activities were authorized and performed against systems owned and administered within the lab environment. No production or third-party systems were targeted.

1. Executive Summary

1.1 Overview

A penetration test was conducted against a multi-system enterprise-style lab environment consisting of:

- Windows 11 workstation
- Windows Server 2025
- Ubuntu Server hosting OWASP Juice Shop

The primary objectives were to evaluate:

- Internal network exposure
- Authentication and authorization mechanisms
- Web application security posture
- Windows service hardening (SMB, RDP, WinRM)
- SSH security configuration
- API security and business logic integrity

1.2 In-Scope Assets

Asset	IP Address	Role	EndPoint_Name
Kali Linux	192.168.1.203	Attacker Machine	Attackerhost
Windows 11	192.168.1.136	Workstation	WIN11
Windows Server	192.168.1.219	Server	WIN-C974KSUQ02A
Ubuntu Server	192.168.1.145	Web Application Host	Target3

1.3 Overall Risk Summary

Severity	Count
Critical	2
High	6
Medium	1

1.4 Key Security Themes Identified

- Broken Access Control across web APIs
- Injection vulnerabilities (SQLi)
- Business logic abuse (financial manipulation)
- Sensitive data exposure (user + file systems)
- Windows service misconfiguration (SMB / RDP /RPC/ Winwam)
- Web application XSS vulnerabilities

2. Methodology (NIST SP 800-115)

Phase 1 – Planning

Defined scope included:

- Internal network (192.168.1.0/24)
- Web application (OWASP Juice Shop)
- Windows services (SMB, RDP, WinRM)
- SSH services

Phase 2 – Discovery (Reconnaissance)

Network Discovery

Command used:

```
nmap -PR -sn 192.168.1.0/24
```

Identified Hosts

- 192.168.1.136 – Windows 11
- 192.168.1.145 – Ubuntu Server
- 192.168.1.219 – Windows Server

```
(attackerhost@kali)-[~]  
$ nmap -PR -sn 192.168.1.0/24 --java-cmd=java --fingerprint=java --script=java --script-args=java --script-args=java --script-args=java  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-08 18:58 -0400  
Nmap scan report for 192.168.1.0  
Host is up (0.0045s latency).  
Nmap scan report for router.home.local (192.168.1.1)  
Host is up (0.0069s latency).  
Nmap scan report for 192.168.1.2  
Host is up (0.99s latency).  
Nmap scan report for 192.168.1.3  
Host is up (0.99s latency).  
Nmap scan report for 192.168.1.4  
Host is up (0.99s latency).  
Nmap scan report for 192.168.1.5  
Host is up (0.99s latency).
```

```
Nmap scan report for 192.168.1.102  
Host is up (0.031s latency).  
Nmap scan report for 192.168.1.103  
Host is up (0.48s latency).  
Nmap scan report for wazuh-server.home.local (192.168.1.104)  
Host is up (0.031s latency).  
Nmap scan report for 192.168.1.105  
Host is up (0.030s latency).  
Nmap scan report for 192.168.1.106  
Host is up (0.48s latency).  
Nmap scan report for 192.168.1.107  
Host is up (0.030s latency).  
Nmap scan report for 192.168.1.108
```

```
Nmap scan report for 192.168.1.135  
Host is up (0.012s latency).  
Nmap scan report for WIN11.home.local (192.168.1.136)  
Host is up (0.012s latency).  
Nmap scan report for 192.168.1.137  
Host is up (0.37s latency).  
Nmap scan report for 192.168.1.138  
Host is up (0.37s latency).  
Nmap scan report for 192.168.1.139  
Host is up (0.0092s latency).  
Nmap scan report for 192.168.1.140  
Host is up (0.0091s latency).  
Nmap scan report for 192.168.1.141  
Host is up (0.28s latency).  
Nmap scan report for 192.168.1.142  
Host is up (0.28s latency).  
Nmap scan report for 192.168.1.143  
Host is up (0.0089s latency).  
Nmap scan report for 192.168.1.144  
Host is up (0.0085s latency).  
Nmap scan report for target3.home.local (192.168.1.145)  
Host is up (0.11s latency).  
Nmap scan report for 192.168.1.146  
Host is up (0.28s latency).  
Nmap scan report for 192.168.1.147
```

```

Host is up (0.16s latency).
Nmap scan report for 192.168.1.218
Host is up (0.16s latency).
Nmap scan report for WIN-C974KSUQ02A.home.local (192.168.1.219)
Host is up (0.043s latency).
Nmap scan report for 192.168.1.220
Host is up (0.16s latency).
Nmap scan report for 192.168.1.221
Host is up (0.16s latency).
Nmap scan report for 192.168.1.222
Host is up (0.16s latency).
Nmap scan report for 192.168.1.223
Host is up (0.16s latency).

```

Phase 3 – Scanning & Enumeration

Full Scan

`nmap -sS -sV -sC -Pn -T3 -iL target_host -oA full_scan_Report`

OS Detection

`nmap -O -iL targets_host`

```

(attackerhost@kali)-[~]
$ touch target_host

(attackerhost@kali)-[~]
$ nano target_host

(attackerhost@kali)-[~]
$ nmap -sS -sV -sC -Pn -T3 -iL target_host -oA Full_Scan_Report
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-08 19:36 -0400
Nmap scan report for WIN11.home.local (192.168.1.136)
Host is up (0.015s latency).
Not shown: 826 filtered tcp ports (no-response), 172 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
445/tcp    open  microsoft-ds?
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ nbstat: NetBIOS name: WIN11, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:84:46:9b (Oracle VirtualBox virtual NIC)
|_ smb2-time:
|   date: 2026-06-08T23:39:21
|_ start_date: N/A
|_ smb2-security-mode:
|   3.1.1:
|     Message signing enabled and required

Nmap scan report for target3.home.local (192.168.1.145)
Host is up (0.012s latency).
Not shown: 799 filtered tcp ports (no-response), 199 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 00:82:86:86:3c:32:51:64:9b:3e:3f:5b:d2:2d:26:7a (ECDSA)
|_  256 c0:3f:e7:4a:ab:c6:ce:3d:50:9b:7f:55:a2:c1:0b:72 (ED25519)
3000/tcp  open  ppp?
|_ fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 200 OK
|     Access-Control-Allow-Origin: *
|     X-Content-Type-Options: nosniff
|     X-Frame-Options: SAMEORIGIN
|     Feature-Policy: payment 'self'
|     X-Recruiting: /#/jobs
|     Accept-Ranges: bytes
|     Cache-Control: public, max-age=0
|     Last-Modified: Mon, 08 Jun 2026 23:34:37 GMT
|     ETag: W/"124fa-19ea9968ec8"
|     Content-Type: text/html; charset=UTF-8
|     Content-Length: 75002
|     Vary: Accept-Encoding
|     Date: Mon, 08 Jun 2026 23:39:20 GMT
|_ Connection: close

```


3. ATTACK SURFACE OVERVIEW

3.1 Hosts Assessed

System	IP	Role
Windows 11	192.168.1.136	Workstation
Windows Server	192.168.1.219	Server
Ubuntu Server	192.168.1.145	Web Application Host

3.2 Key Exposed Services

- SMB (445)
- RDP (3389)
- RPC (135)
- Netbios-ssn(139)
- Winman (5985)
- WSDAPI (5357)
- SSH (22)
- HTTP (3000 – Juice Shop)

4. INFRASTRUCTURE SECURITY FINDINGS

4.1 Windows Server (192.168.1.219)

Observed Services:

- SMB (445)
- RDP (3389)
- RDP (3389)
- RPC (135)
- WinRM (5985)
- WSDAPI (5357)

```
(attackerhost@kali)-[~]
$ nmap -p445 --script smb2-security-mode 192.168.1.219
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-10 18:09 -0400
Nmap scan report for WIN-C974KSUQ02A.home.local (192.168.1.219)
Host is up (0.030s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: E4:1F:D5:E7:57:B1 (Intel Corporate)

Host script results:
| smb2-security-mode:
|   3.1.1:
|_  Message signing enabled but not required

Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds
```

```
(attackerhost@kali)-[~]
$ nmap -sV -Pn -p3389 --script rdp-enum-encryption,rdp-ntlm-info,rdp-vuln-ms12-020,ssl-cert 192.168.1.219
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-10 17:51 -0400
Nmap scan report for WIN-C974KSUQ02A.home.local (192.168.1.219)
Host is up (0.066s latency).

PORT      STATE SERVICE      VERSION
3389/tcp  open  ms-wbt-server?
| ssl-cert: Subject: commonName=WIN-C974KSUQ02A
| Issuer: commonName=WIN-C974KSUQ02A
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-04-15T00:24:10
| Not valid after: 2026-10-15T00:24:10
| MD5: fb37 d699 c6fa 51ba 96bf 575c 674c 83af
| SHA-1: 3902 2fa3 adc8 58e3 1ec2 4eb0 6891 20a6 4b73 7082
|_ SHA-256: 054c 447c ce96 f564 4e05 a7dc 4ec7 e12f 676d 8a55 13a8 b66f 14a5 b460 e7c8 03a1
| rdp-enum-encryption:
|   Security layer
|   CredSSP (NLA): SUCCESS
|   CredSSP with Early User Auth: SUCCESS
|   RDSTLS: SUCCESS
|_ rdp-ntlm-info:
|   Target_Name: WIN-C974KSUQ02A
|   NetBIOS_Domain_Name: WIN-C974KSUQ02A
|   NetBIOS_Computer_Name: WIN-C974KSUQ02A
|   DNS_Domain_Name: WIN-C974KSUQ02A
|   DNS_Computer_Name: WIN-C974KSUQ02A
|   Product_Version: 10.0.26100
|_ System_Time: 2026-06-10T21:52:09+00:00
MAC Address: E4:1F:D5:E7:57:B1 (Intel Corporate)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 49.29 seconds
```

```
(attackerhost@kali)-[~]
$ rpcclient -U "" 192.168.1.219
Password for [WORKGROUP\]:
Cannot connect to server. Error was NT_STATUS_LOGON_FAILURE
```

```
(attackerhost@kali)-[~]
$ nmap -p5357 --script http-headers,http-methods,upnp-info,http-vuln-cve2015-1635 192.168.1.219
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-10 18:35 -0400
Nmap scan report for WIN-C974KSUQ02A.home.local (192.168.1.219)
Host is up (0.089s latency).

PORT      STATE SERVICE
5357/tcp  open  wsdapi
MAC Address: E4:1F:D5:E7:57:B1 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 0.35 seconds
```



```

(attackerhost@kali)-[~]
$ nmap -p5985 --script http-auth,http-headers,http-methods,http-vuln-cve2015-1635 192.168.1.219
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-10 18:54 -0400
Nmap scan report for WIN-C974KSUQ02A.home.local (192.168.1.219)
Host is up (0.089s latency).

PORT      STATE SERVICE
5985/tcp  open  wsman

MAC Address: E4:1F:D5:E7:57:B1 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 0.36 seconds

```

Findings

- SMB Misconfiguration: Signing enabled but not required
- RDP Exposure: NTLM authentication observed
- Port 5357 (WSMAN) Exposure: Metadata accessible
- Port 5357 (WSDAPI): Device discovery service exposed

Business Impact:

- Increased lateral movement risk
- Remote administrative abuse potential
- Expanded attack surface for internal compromise

4.2 Windows 11 (192.168.1.136)

Observed Services:

- SMB (445)
- RPC (135)

SMB Hardening Check:

nmap --script smb2-security-mode 192.168.1.136

```
(attackerhost@kali)-[~]
$ nmap -p445 --script smb2-security-mode 192.168.1.136
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-09 17:45 -0400
Nmap scan report for WIN11.home.local (192.168.1.136)
Host is up (0.0017s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled and required

Nmap done: 1 IP address (1 host up) scanned in 0.20 seconds
```

```
(attackerhost@kali)-[~]
$ rpcclient -U "" 192.168.1.136
Password for [WORKGROUP\]:
rpcclient $> enumdomusers
result was NT_STATUS_CONNECTION_DISCONNECTED
rpcclient $> enumdomgroups
result was NT_STATUS_CONNECTION_DISCONNECTED
rpcclient $> netshareenumall
result was WERR_ACCESS_DENIED
rpcclient $> querydomaininfo
result was NT_STATUS_CONNECTION_DISCONNECTED
rpcclient $>
```

Result:

- SMB signing enabled and required
- Fully hardened configuration

Conclusion: Secure baseline configuration and no exploitable SMB weaknesses

Business Impact:

- Low risk compared to server systems
- Proper baseline security posture

4.3 Ubuntu Server (192.168.1.145)

Observed Services:

- SSH (22)
- Web Application (3000 – Juice Shop)

```
(attackerhost@kali)-[~]  
$ nmap -p22 --script ssh-auth-methods 192.168.1.145  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-15 19:44 -0400  
Nmap scan report for target3.home.local (192.168.1.145)  
Host is up (0.053s latency).  
  
PORT      STATE SERVICE  
22/tcp    open  ssh  
| ssh-auth-methods:  
|   Supported authentication methods:  
|   publickey  
|_  password  
MAC Address: E4:1F:D5:E7:57:B1 (Intel Corporate)  
  
Nmap done: 1 IP address (1 host up) scanned in 2.29 seconds
```

```
(attackerhost@kali)-[~]  
$ curl -I http://192.168.1.145:3000  
HTTP/1.1 200 OK  
Access-Control-Allow-Origin: *  
X-Content-Type-Options: nosniff  
X-Frame-Options: SAMEORIGIN  
Feature-Policy: payment 'self'  
X-Recruiting: /#/jobs  
Accept-Ranges: bytes  
Cache-Control: public, max-age=0  
Last-Modified: Tue, 16 Jun 2026 18:28:32 GMT  
ETag: W/"124fa-19ed1b1383a"  
Content-Type: text/html; charset=UTF-8  
Content-Length: 75002  
Vary: Accept-Encoding  
Date: Tue, 16 Jun 2026 19:03:11 GMT  
Connection: keep-alive  
Keep-Alive: timeout=5
```

Carrot Juice
(1000ml)
2.99\$

```
(attackerhost@kali)-[~]
$ gobuster dir \
-u http://192.168.1.145:3000 \
-w /usr/share/seclists/Discovery/Web-Content/common.txt \
> --exclude-length 75002

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.1.145:3000
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] Exclude Length: 75002
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.well-known/security.txt (Status: 200) [Size: 475]
Video (Status: 200) [Size: 10075518]
api (Status: 500) [Size: 3011]
api/experiments (Status: 500) [Size: 3035]
api/experiments/configurations (Status: 500) [Size: 3065]
apis (Status: 500) [Size: 3013]
assets (Status: 301) [Size: 156] [→ /assets/]
ftp (Status: 200) [Size: 11307]
media (Status: 301) [Size: 155] [→ /media/]
profile (Status: 500) [Size: 1049]
promotion (Status: 200) [Size: 6459]
redirect (Status: 500) [Size: 3113]
rest (Status: 500) [Size: 3013]
restore (Status: 500) [Size: 3019]
restaurants (Status: 500) [Size: 3027]
restricted (Status: 500) [Size: 3025]
restored (Status: 500) [Size: 3021]
robots.txt (Status: 200) [Size: 28]
security.txt (Status: 200) [Size: 475]
video (Status: 200) [Size: 10075518]
Progress: 4750 / 4750 (100.00%)
=====
Finished
=====
```

Observations:

- SSH exposed with password authentication
- Web application fully exposed (port 3000)

Business Impact:

- Credential brute-force risk (SSH)
- Primary attack entry point via web application

5. Application Security Findings (OWASP Juice Shop)

Below are the validated vulnerabilities discovered during testing.

F1 – Feedback Access Control Weakness

Severity: High

CVSS v3.1: 8.1 (High)

MITRE ATT&CK:

- Exploit Public-Facing Application (T1190)
- Abuse Elevation Control Mechanism (T1548)

Description:

The feedback feature lacked proper object-level authorization, allowing users to access or modify feedback entries they did not own.

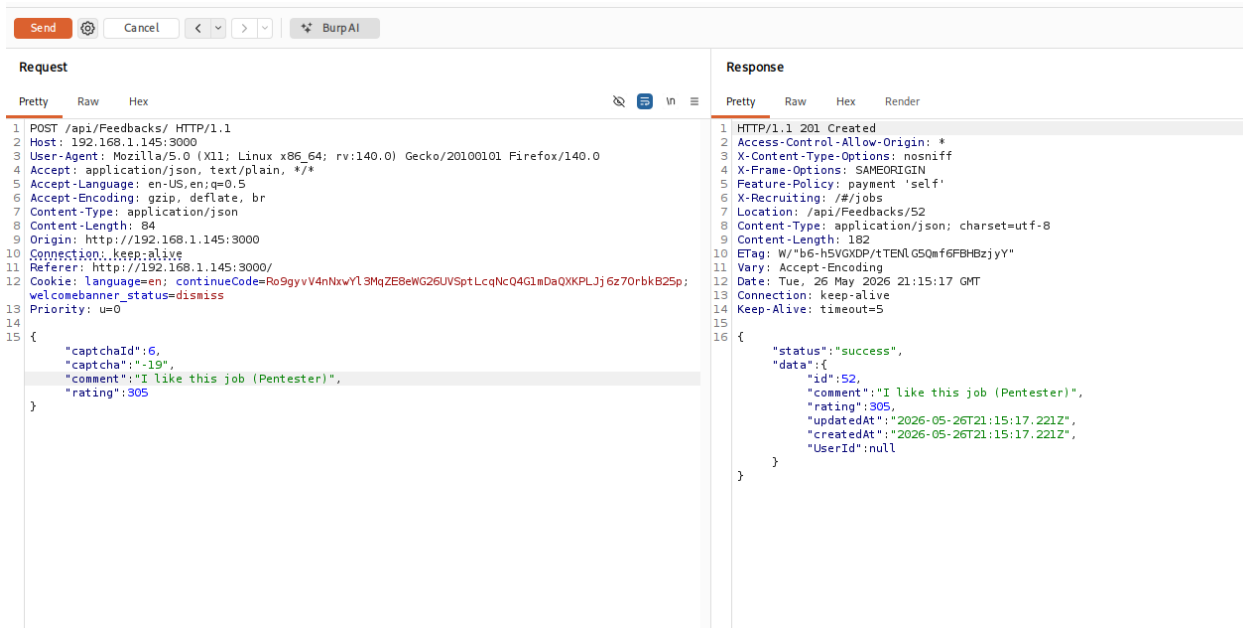
Business Impact:

- Unauthorized modification of user-generated content
- Loss of application data integrity
- Reputational damage due to content manipulation
- Increased risk of abuse of application functionality
- Potential regulatory and compliance concerns if user-submitted data is altered without authorization

The screenshot displays the Burp Suite interface with a request and response view. The request is a POST to /api/Feedbacks/ HTTP/1.1. The response is a 201 Created status with a JSON body indicating success.

```
Request
1 POST /api/Feedbacks/ HTTP/1.1
2 Host: 192.168.1.145:3000
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/json
8 Content-Length: 85
9 Origin: http://192.168.1.145:3000
10 Connection: keep-alive
11 Referer: http://192.168.1.145:3000/
12 Cookie: language=en; continueCode=Ro9gyvV4nNxvYl3MqZE8eWG26UVSptLcQnQ4G1mDaQXXPLJj6z70rbk825p; welcomebanner_status=dismiss
13 Priority: u=0
14
15 {
  "captchaId":6,
  "captcha":"-19",
  "comment":"It is not that bad (anonymous)",
  "rating":5
}
```

```
Response
1 HTTP/1.1 201 Created
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Location: /api/Feedbacks/51
8 Content-Type: application/json; charset=utf-8
9 Content-Length: 183
10 ETag: W/"b7-NYWDYKwsP6df7TDns9xhxxorCk"
11 Vary: Accept-Encoding
12 Date: Tue, 26 May 2026 21:11:41 GMT
13 Connection: keep-alive
14 Keep-Alive: timeout=5
15
16 {
  "status":"success",
  "data":{
    "id":51,
    "comment":"It is not that bad (anonymous)",
    "rating":5,
    "updatedAt":"2026-05-26T21:11:41.567Z",
    "createdAt":"2026-05-26T21:11:41.567Z",
    "userId":null
  }
}
```



F2– Sensitive Data Exposure (/rest/memories)

Severity: High

CVSS: 8.6

MITRE:

Data from Information Repositories (T1213)

Description:

The endpoint exposes user credentials, including email addresses and password hashes without adequate authorization controls.

Business Impact:

- Credential reuse attacks on external systems
- Account takeover risk
- Identity theft potential
- Regulatory compliance exposure (GDPR-like impact)

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 GET /rest/memories/ HTTP/1.1 2 Host: 192.168.1.145:3000 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json, text/plain, */* 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Connection: keep-alive 8 Referer: http://192.168.1.145:3000/ 9 Cookie: language=en; continueCode=Ro9gyvV4nNwYl3MqZE8eWG26UVSptLcQn04G1mDaQXKPLJj6z70rbk825p; welcomebanner_status=dismiss Content-Length: 2 </pre>			<pre> 1 HTTP/1.1 200 OK 2 Access-Control-Allow-Origin: * 3 X-Content-Type-Options: nosniff 4 X-Frame-Options: SAMEORIGIN 5 Feature-Policy: payment 'self' 6 X-Recruiting: /#/jobs 7 Content-Type: application/json; charset=utf-8 8 ETag: W/"1827-b0EvJr/nXkPRDc+hGSP30cW0xk" 9 Vary: Accept-Encoding 10 Date: Tue, 26 May 2026 21:31:59 GMT 11 Connection: keep-alive 12 Keep-Alive: timeout=5 13 Content-Length: 6183 14 15 { "status": "success", "data": { { "UserId": 13, "id": 1, "caption": "[] #zatschi #whoneedsfourlegs", "imagePath": "assets/public/images/uploads/L0J-#zatschi-#whoneedsfourlegs-1572600969477.jpg", "createdAt": "2026-05-25T09:10:59.819Z", "updatedAt": "2026-05-25T09:10:59.819Z", "User": { "id": 13, "username": "", "email": "bjoern@owasp.org", "password": "9283f1b2e9669749081963be0462e466", "role": "deluxe", "deluxeToken": "efe2f1599e2d93440d5243affaf5a413b70cf3ac97156bd6fab9b5ddfcbe0e4", "lastLoginIp": "", "profileImage": "assets/public/images/uploads/13.jpg", "totpSecret": "", "isActive": true, "createdAt": "2026-05-25T09:10:52.096Z", "updatedAt": "2026-05-25T09:10:52.096Z", "deletedAt": null } } } } </pre>			

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 GET /rest/memories/ HTTP/1.1 2 Host: 192.168.1.145:3000 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json, text/plain, */* 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Connection: keep-alive 8 Referer: http://192.168.1.145:3000/ 9 Cookie: language=en; continueCode=Ro9gyvV4nNwYl3MqZE8eWG26UVSptLcQn04G1mDaQXKPLJj6z70rbk825p; welcomebanner_status=dismiss Content-Length: 2 </pre>			<pre> "id": 4, "username": "bkimminich", "email": "bjoern.kimminich@gmail.com", "password": "6edd9d726cbdc873c539e41ae8757b8c", "role": "admin", "deluxeToken": "", "lastLoginIp": "", "profileImage": "assets/public/images/uploads/defaultAdmin.png", "totpSecret": "", "isActive": true, "createdAt": "2026-05-25T09:10:52.099Z", "updatedAt": "2026-05-25T09:10:52.099Z", "deletedAt": null }, { "UserId": 21, "id": 4, "caption": "Welcome to the Bee Haven (/#/bee-haven)[]", "imagePath": "assets/public/images/uploads/BeeHaven.png", "createdAt": "2026-05-25T09:10:59.620Z", "updatedAt": "2026-05-25T09:10:59.620Z", "User": { "id": 21, "username": "avarox", "email": "etherium@juice-sh.op", "password": "2c17c6399771ee3048ae34d6b380c5ec", "role": "deluxe", "deluxeToken": "b49b30b294d8c76f5a34fc243b9b9cccb057b3f675b07a5782276a547957f8ff", "lastLoginIp": "", "profileImage": "assets/public/images/uploads/defaultAdmin.png", "totpSecret": "", "isActive": true, "createdAt": "2026-05-25T09:10:52.099Z", "updatedAt": "2026-05-25T09:10:52.099Z", "deletedAt": null } } </pre>			

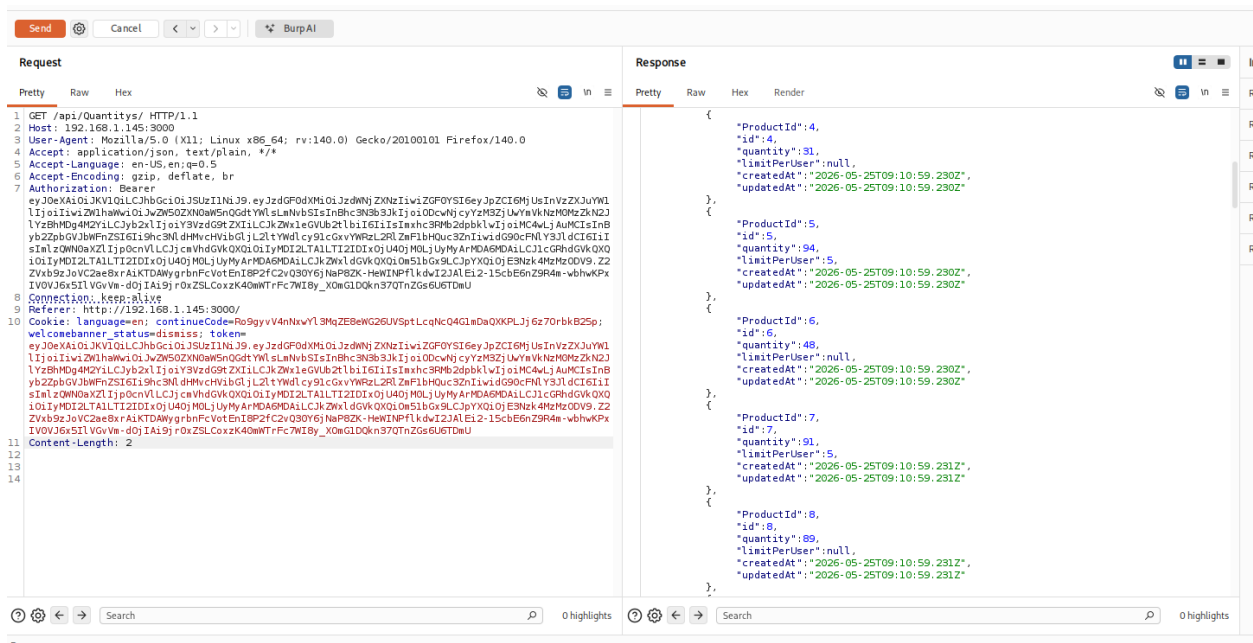
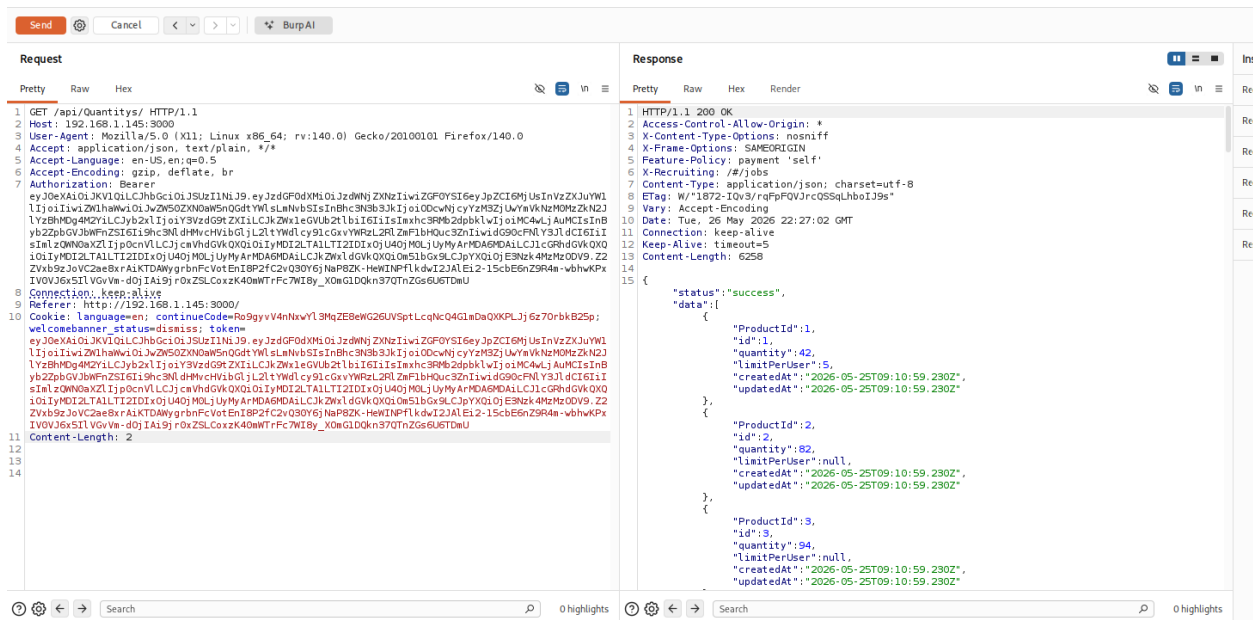
F3 – API Overexposure (/api/quantity)

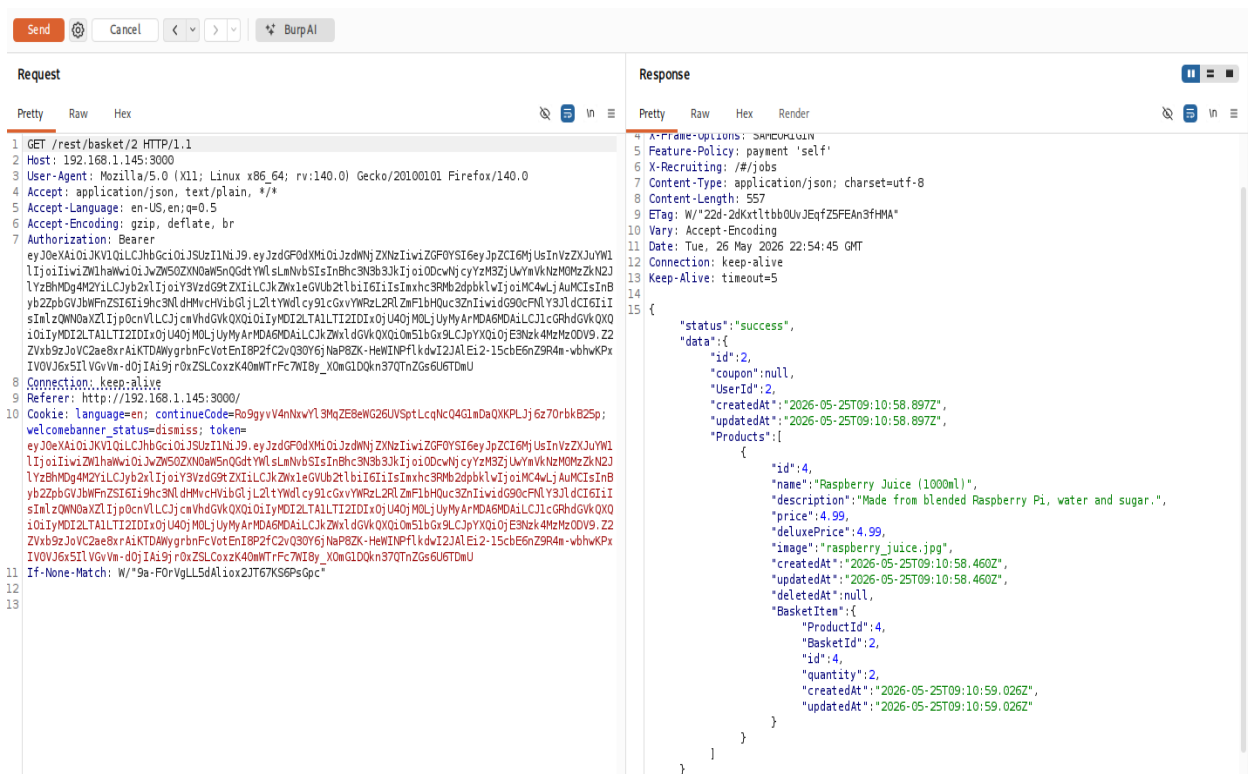
Severity: Medium

CVSS: 4.3

Business Impact:

- Unnecessary exposure of inventory logic
- Reconnaissance value for attackers
- Supports targeted exploitation of business workflows





F5– Business Logic Manipulation (Negative Quantity Abuse)

Severity: High

CVSS: 7.5

MITRE:

Abuse Elevation Control Mechanism (T1548)

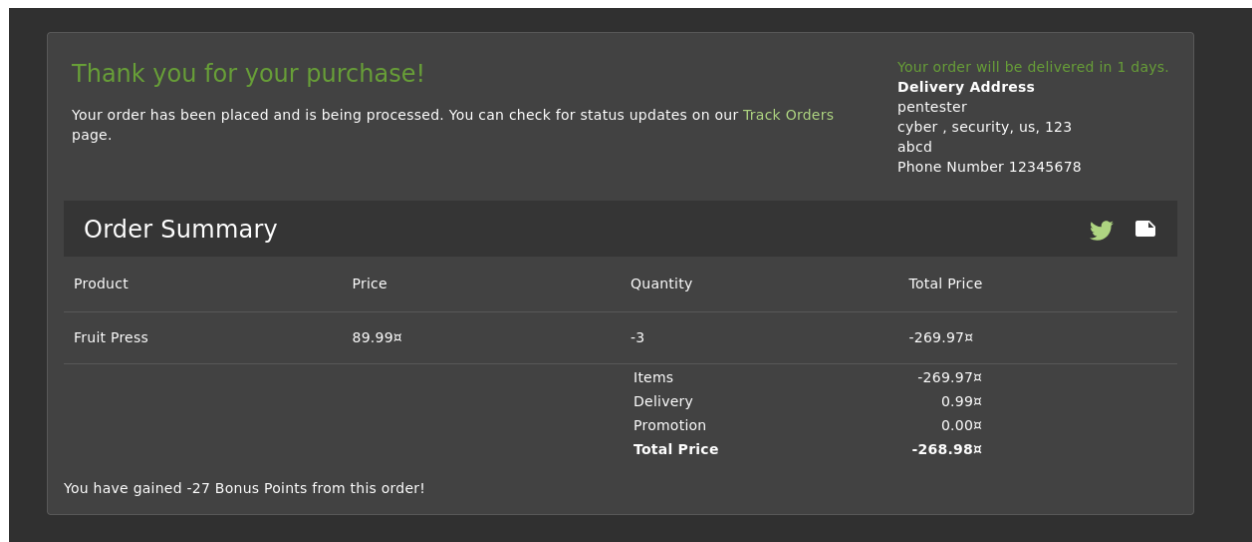
Description:

The application does not validate quantity constraints, allowing negative values that result in unintended wallet credit.

Business Impact:

- Direct financial loss through system abuse
- Fraudulent credit generation
- Breakdown of payment integrity controls

- Potential exploitation in real financial environments



F6 – Confidential File Exposure (/ftp/acquisition)

Severity: High

CVSS: 7.8

MITRE:

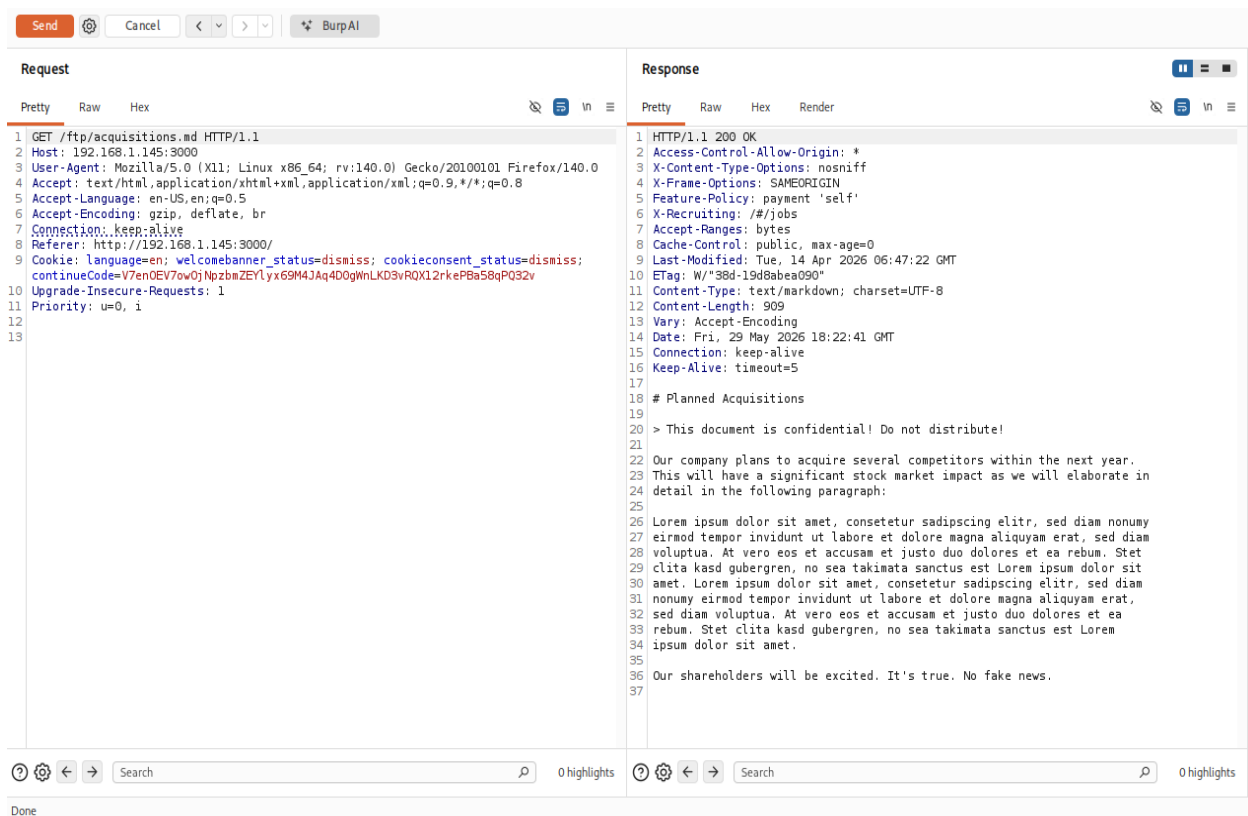
Data Exposure (T1081)

Description:

Sensitive internal documents are accessible via direct HTTP access without authentication.

Business Impact:

- Exposure of confidential business information
- Competitive intelligence leakage
- Increased risk of social engineering attacks
- Potential regulatory or contractual violations



F7 – SQL Injection Authentication Bypass

Severity: Critical

CVSS: 9.8

MITRE:

Exploit Public-Facing Application(T1190)

Description:

The authentication mechanism is vulnerable to SQL Injection, allowing unauthorized login without valid credentials.

Business Impact:

- Full compromise of application authentication system
- Unauthorized access to user accounts and administrative functions
- Potential exposure of all backend database records
- Loss of trust in authentication integrity

Login

Email*

' OR 1=1--

Password*

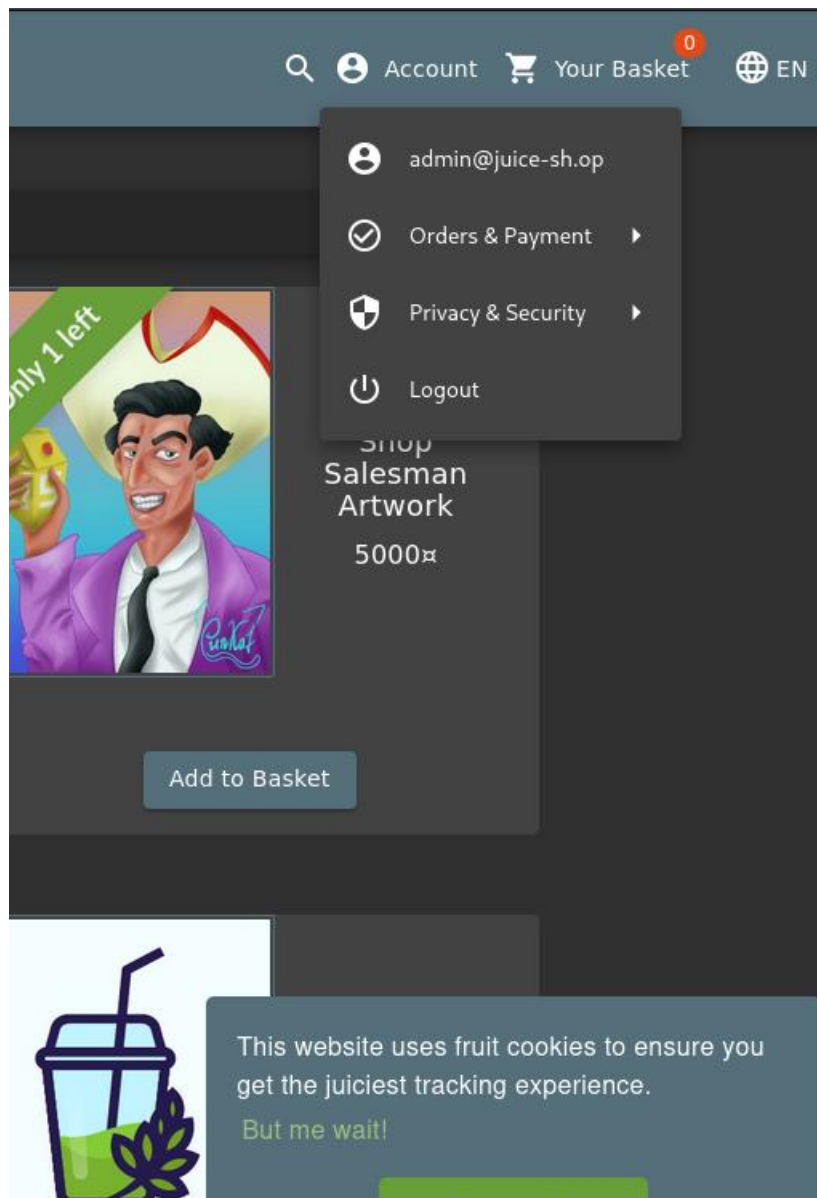
••••• 

[Forgot your password?](#)

 Log in

☐ Remember me

[Not yet a customer?](#)



F8 – SQL Injection (Search Functionality)

Severity: Critical

CVSS: 9.1

MITRE:

Exploit Public-Facing Application (T1190)

Description:

Business Impact:

- [illegible]

Severity: High

CVSS: 7.4

MITRE:

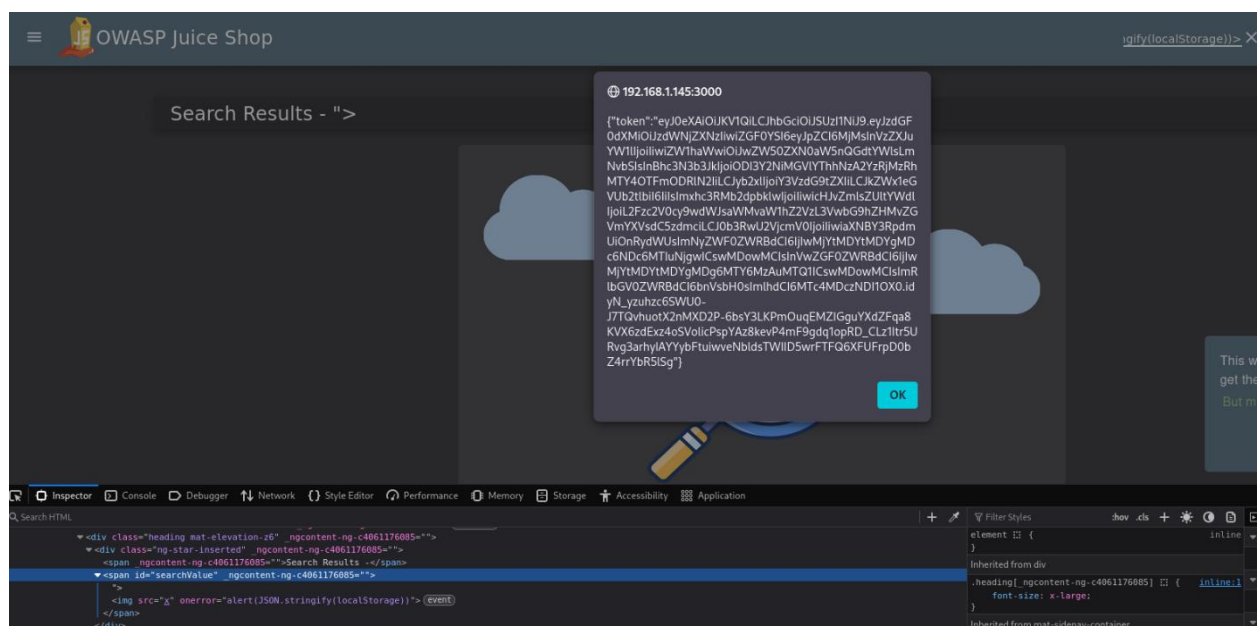
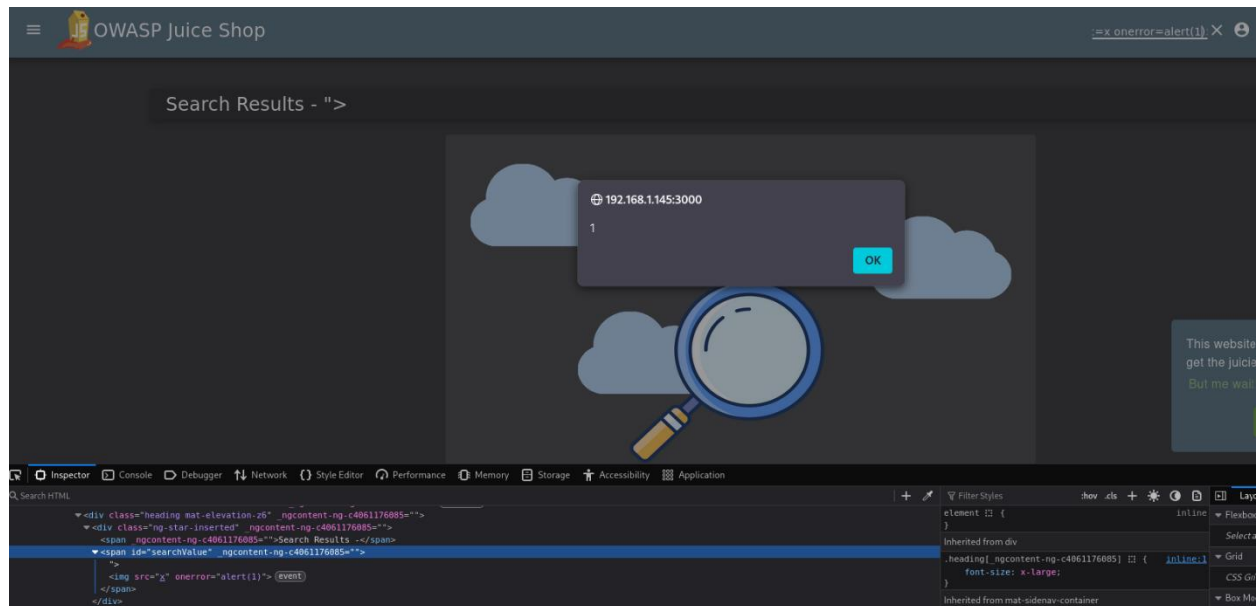
Command and Scripting Interpreter (T1059.007)

Description:

User input is rendered without proper sanitization, enabling execution of malicious scripts in the browser.

Business Impact:

- Session hijacking risk
- Token theft
- Client-side account compromise
- Phishing and user manipulation attacks



6. RISK SUMMARY

Critical Risks:

- Authentication bypass (SQL Injection)
- Database compromise

High Risks:

- IDOR
- Business logic manipulation
- Sensitive data exposure
- XSS exploitation
- File exposure

Medium Risks:

- API overexposure
- Multiple services exposed internally

7. OVERALL BUSINESS IMPACT

If this environment were production, the identified vulnerabilities could result in:

- Full compromise of user authentication systems
- Exposure of sensitive customer and business data
- Financial fraud via logic manipulation
- Unauthorized access to internal systems
- Regulatory compliance violations
- Loss of customer trust and reputational damage

8. RECOMMENDATIONS

Immediate Actions:

- Eliminate SQL Injection vulnerabilities using parameterized queries
- Secure authentication and session management
- Remove sensitive data exposure from APIs

High Priority:

- Implement strict access control (RBAC/ABAC)
- Fix IDOR vulnerabilities in all APIs
- Validate all business logic server-side
- Restrict access to internal documents

Infrastructure Hardening:

- Disable unnecessary or unused services to reduce system exposure, lower lateral-movement opportunities, and strengthen overall security posture
- Harden SMB configuration by enforcing mandatory SMB signing to prevent relay attacks and ensure message integrity.
- Restrict RDP access to trusted networks only to reduce exposure of remote access services and limit lateral-movement opportunities.

9. Conclusion

The assessment revealed a multi-layered attack surface across network, system, and application layers. The most critical risks identified were:

- SQL Injection (authentication bypass)
- Broken Access Control (IDOR)
- Business logic exploitation
- Sensitive data exposure

If deployed in production, these vulnerabilities could enable:

- Full application compromise

- Data exfiltration
- Account takeover
- Financial manipulation